



HUMAN VERIFICATION · BEHAVIORAL SECURITY

Security CAPTCHA

행동 기반 차세대 보안 인증

사람은 사물을 끌어다 놓는 것만으로 흐르듯 자연스럽게 통과하고, 봇은 **13겹의 심층 방어**와 행동 AI로 확실하게 걸러냅니다. 이미지 한 장을 인식하면 뚫리는 기존 캡차의 시대를 넘어섭니다.

Object-Drag Interaction

Behavioral AI · LightGBM

Adaptive Proof-of-Work

Tamper-proof Server Verification

On-Premise · Data Sovereignty

EXECUTIVE SUMMARY

한눈에 보는 CatChap

직관적인 상호작용 위에 '어떻게 움직였는가'를 서버가 신뢰가능하게 분석하는 행동 AI를 결합한, 온프레미스 보안 캡차입니다.

13겹

독립 방어 기법(5계층)
Defense-in-Depth

1,660

사람 검수 완료 문항풀
Human-reviewed
Question Pool

AI

행동 분석 모델 상시가동
LightGBM · Shadow 검증
중

100%

서버측 위조불가 검증
Tamper-proof Receipt
Chain



무엇을 만들었나

사용자는 화면의 지정 사물을 정답 영역으로 **드래그**하면 끝입니다. 3초 내의 직관적 상호작용이지만, 그 사이 발생하는 마우스·포인터 궤적을 서버가 **위조 불가능한 채널**로 수집해 사람 다음을 판별합니다. 정답을 알아도 **사람처럼 움직이지 않으면** 통과하지 못합니다.



왜 다른가

기존 캡차는 '이미지를 인식'하면 뚫립니다 — 오늘날 비전 AI는 사람보다 잘 읽습니다. CatChap은 인식이 아니라 **행동**을 검증합니다. 여기에 PoW·허니팟·문합회전·자동화탐지를 겹쳐, 단일 우회로가 존재하지 않는 **다층 방어**를 구성했습니다.

핵심 요약. CatChap은 (1) 누구나 3초에 푸는 **드래그 UX**, (2) 서버가 신뢰하는 **행동 데이터 파이프라인**, (3) 사람·봇을 가르는 **행동 AI**, (4) 이 셋을 감싸는 **13겹 방어 스택**으로 이루어진, 데이터 주권을 지키는 온프레미스 보안 인증 솔루션입니다.

적용 맥락 · TARGET DOMAIN

이러닝 무결성

인터넷 강의의 부정수강·대리출석·자동 진도이수 봇 차단. "사람이 실제로 조작했는가"가 수강 인정의 핵심입니다.

회원가입 · 로그인

대량 계정 생성, 크리덴셜 스테핑, 자동 폼 제출을 상호작용+행동 단계에서 저지합니다.

콘텐츠 보호

스크래핑·자동 예약·티켓팅 매크로 등, 정밀 사람흉내 봇까지 겨냥한 범용 봇 방어.

THE PROBLEM

기존 캡차는 왜 뚫리는가

문자 왜곡과 이미지 선택은 'AI가 사람보다 못 본다'는 전제 위에 서 있었습니다. 그 전제가 무너졌습니다.

1 인식의 붕괴

OCR·비전 모델이 왜곡문자·신호등·횡단보도를 사람보다 정확히 읽습니다. '인식을 시험하는' 캡차는 이미 AI에게 유리한 시험입니다.

2 UX 마찰

반복 실패, 흐릿한 이미지, 여러 라운드의 피로. 정작 사람이 이탈하고, 전환율을 떨어뜨립니다.

3 데이터 주권

글로벌 캡차는 사용자 행동·쿠키를 외부로 전송·프로파일링합니다. 국내 서비스엔 프라이버시·규제 리스크입니다.

정밀 사람홍내 봇 · THE REAL THREAT

진짜 위협은 조잡한 스크립트가 아니라, 브라우저 자동화(Playwright·Puppeteer)로 실제 이벤트 루프에서 사람과 유사한 타이밍·궤적을 만드는 봇입니다. 단순 정답 제출만 보는 캡차는 이들을 구분할 수 없습니다. 핵심 질문은 "무엇을 골랐는가"가 아니라 "어떻게 움직였는가"로 이동했습니다.

구분	전통적 캡차 (문자/이미지)	CATCHAP 접근
시험 대상	이미지 인식 능력 ← AI 우위	상호작용 행동 ← 사람 우위
봇 우회법	비전 모델 1회 추론	단일 우회 불가 (다층 · 행동 검증)
사용자 부담	반복 선택·실패	사물 하나 드래그 (약 3초)
데이터	외부 전송·프로파일링	온프레미스 · 자체 보관

THE SOLUTION

드래그 위에 얹은 행동 지능

직관적 상호작용(누구나 통과)과 서버 신뢰 행동 분석(봇만 탈락)을 하나로 묶었습니다.



축 1 — 오브젝트 드래그

화면 위 지정된 사물을 정답 영역으로 끌어다 놓습니다. 직관적이고 언어 독립적이며, 모바일 터치에도 자연스럽게습니다.

- 정답 사물은 **보이지 않는 히트영역**으로 배치 — 화면 픽셀만 봐선 위치를 알 수 없음
- 매 요청마다 객체 ID를 **임시값으로 재매핑** — 재사용·리플레이 차단
- 정답존 좌표를 **매번 랜덤화** — 고정 좌표 자동화 무력화



축 2 — 서버 신뢰 행동 AI

드래그 중 발생하는 포인터 이벤트를 **영수증 체인 배치채널**로 서버에 전송·저장하고, 그 서버측 원본으로 판별합니다. 클라이언트가 조작한 값이 아닙니다.

- 속도·가속·궤적 곡률·정지-재개 패턴을 **휴리스틱 + 머신러닝**으로 이중 채점
- 모델은 **LightGBM** 기반 별도 마이크로서비스로 분리 운영
- 정답을 알아도 **사람다운 움직임**을 통과해야 함

사용자 경험 · ONE INTERACTION

SEE

문제 제시

"고양이를 상자 안으로" 같은 지시와 이미지가 나타남



DRAG

끌어놓기

대상 사물을 정답 영역으로 드래그



PASS

즉시 통과

사람은 마찰 없이 통과, 봇은 다층에서 탈락

사용자에게 보이는 건 **단 한 번의 드래그**뿐입니다. PoW 연산, 행동 수집, 허니팟, AI 채점은 모두 **배경에서 조용히** 수행되어 UX를 해치지 않습니다.

HOW IT WORKS

04

챌린지 생성부터 검증까지

모든 단계에 방어가 내장된 4단계 파이프라인. 각 단계가 다음 단계의 신뢰 근거가 됩니다.

① 챌린지 생성 Server

문항풀에서 최소노출·쿨다운 기준으로 문항을 선정하고, 방어 장치를 심어 발급합니다.

은닉 히트영역 임시 ID 리매핑 허니팟 함정 배치 드롭존 랜덤화 적응형 PoW 시드



② 클라이언트 풀이 Browser

위젯이 PoW를 백그라운드 워커로 연산하고, 사용자의 드래그 이벤트를 실시간으로 서버에 스트리밍합니다.

SHA-256 PoW 워커 포인터 이벤트 수집 배치채널 전송(영수증 체인)



③ 다단 검증 Server

여러 관문을 순서대로 통과해야 합니다. 하나라도 걸리면 차단 또는 재도전(step-up)으로 강등됩니다.

PoW 게이트 허니팟 즉시차단 정답 판정 행동 휴리스틱 채점 행동 AI 채점 자동화·클러스터 탐지



④ 토큰 발급 · 재검증 Server ↔ Site

통과 시 일회성 토큰을 발급하고, 도입 사이트는 사이트 시크릿으로 서버-대-서버 재검증합니다.

1회용 토큰 site_secret 재검증 재사용 방지

위조 방지의 핵심. 최종 판정은 클라이언트가 제출한 값이 아니라, 배치채널로 서버에 미리 저장된 행동 원본으로 이뤄집니다. 각 배치는 이전 배치의 영수증에 체인으로 묶여, 중간 조작·누락·재전송을 서버가 감지합니다.

13겹의 심층 방어 스택

단일 방어는 언젠가 뚫립니다. CatChap은 성격이 다른 13개 방어를 5계층으로 겹쳐, 우회 비용을 비대칭적으로 끌어올립니다.

L1 입구	① 적응형 Proof-of-Work	세션 위험도로 난이도 상향 · 연산비용 부과
L2 문제	② 은닉 히트영역	화면만 봐선 정답 위치 불명
	③ 임시 ID 리매핑	매 요청 새 값 · 리플레이 차단
	④ 허니팟 함정	투명 함정 접촉 즉시 봇 확정
	⑤ 드롭존 랜덤화	고정좌표 자동화 무력화
L3 행동	⑥ 신뢰 이벤트 배치채널(영수증 체인)	서버측 위조불가 원본 확보
	⑦ 행동 휴리스틱 채점	속도·궤적·타이밍 규칙 판별
	⑧ behavior-AI (LightGBM)	행동 학습 모델 채점(shadow)
L4 정황	⑨ 자동화 · 헤드리스 탐지	webdriver·headless 신호 점수화
	⑩ 클러스터 탐지 (행동 지문)	동일 패턴 대량 세션 군집 식별
L5 경계	⑪ 레이트리밋	IP당 요청 제한
	⑫ Origin · CSP 검증	도메인 잠금 · 프레임링 차단
	⑬ 문항 회전	최소노출·쿨다운 노출 분산



적응형 PoW

정상 사용자엔 수백 ms의 무해한 연산이지만, 대량 자동화엔 세션마다 누적되는 비용의 벽이 됩니다. 위험 세션엔 난이도를 자동 상향.



허니팟

사람 눈엔 안 보이는 투명 함정을 실객체와 구분 불가하게 섞어 배치. 접촉하면 즉시 봇으로 확정합니다.



문항 회전

최소노출 + 쿨다운으로 같은 문항이 반복 노출되지 않게 분산. 문항 유출·암기 자동화를 늦춥니다.

행동 AI 파이프라인

"어떻게 움직였는가"를 학습하는 모델. 안전하게 검증(shadow)한 뒤에만 실집행으로 승격합니다.



안전한 승격 원칙

모델이 사람을 봇으로 오판(false positive)하면 정상 사용자가 막힙니다. 그래서 CatChap은 **2단계 승격**을 씁니다 — 먼저 shadow로 충분한 표본에서 **오탐률·참여자별 통과율**을 확인하고, go/no-go 판정을 통과한 뒤에만 실집행합니다. 승격 준비도는 전용 관리 엔드포인트로 상시 확인합니다.



레드팀 봇 라벨링

진짜 봇은 자기 데이터를 주지 않습니다. 그래서 **우리가 봇을 만들어** 라벨을 공급합니다 — 순간이동·직선등속·규칙적·지터·사람홍내곡선 등 다양한 프로파일이 전체 파이프라인을 거치게 하고, **합성 타이밍 vs 실제 타이밍** 두 축으로 나눠 모델이 무엇을 근거로 판별하는지 측정합니다.

현재 상태(정직한 보고). 행동 AI는 **SHADOW** 모드로 **판정에 개입하지 않고** 상시 예측을 기록 중입니다. 내부 레드팀 검증에서 다양한 봇 프로파일을 사람일 확률 ≈ 0 으로 식별함을 확인했으며, 실트래픽 표본을 확보하는 대로 오탐률 기준을 검토해 실집행 승격을 진행합니다. 승격 전까지는 PoW·허니팟·휴리스틱이 안전망 역할을 합니다.

SYSTEM ARCHITECTURE

시스템 구성

관심사를 분리한 모듈형 구조. 캡차 로직과 행동 모델을 독립 서비스로 나눠, 각각을 안전하게 배포·롤백합니다.

① 임베드 위젯 Frontend

도입 사이트에 삽입되는 경량 위젯. 드래그 UI, PoW 위커, 행동 스트리밍을 담당.

React / Vanilla

Web Worker

배치 전송

② 캡차 API 백엔드 Core

챌린지 생성·검증·토큰·관리 API. 방어 스택 대부분이 여기서 집행됩니다.

FastAPI

PoW·허니팟·회전

토큰 발급

③ 데이터 스토어 Data

문항·챌린지·토큰·행동 원본·모델 예측을 보관. 운영/학습 데이터를 역할별로 분리.

MySQL

행동 이벤트

학습 데이터셋

④ 행동 모델 서비스 AI

캡차 코어와 분리된 내부 전용 마이크로서비스. 외부에 노출되지 않습니다.

LightGBM

내부 전용

Shadow/Active

데이터 흐름 · DATA FLOW

사이트

위젯 삽입

도입 페이지에 캡차 위젯 로드

코어

챌린지·검증

방어 집행 + 행동 원본 저장

AI

행동 채점

내부 호출로 사람다움 예측

사이트

토큰 재검증

서버-대-서버로 결과 확인

안전 배포

무중단 재시작 + 즉시 롤백 경로를 갖춘 서비스 관리. 장애 시 이전 빌드로 복귀.

비밀 관리

사이트 시크릿·관리자 키를 코드와 분리 보관하고 정기 로테이션. 채팅·저장소에 비밀 미노출 원칙.

데이터 주권

모든 행동 데이터를 자체 인프라에 보관. 외부 캡차로의 사용자 데이터 유출이 없습니다.

차별점과 경쟁력

글로벌 캡차 대비, 데이터 주권과 봇 저항의 축에서 뚜렷한 우위를 지향합니다.

항목	문자/이미지 캡차	글로벌 행동 캡차	CATCHAP
검증 축	이미지 인식	행동(외부)	행동(자체·서버검증)
정밀 사람홍내 봇	취약	부분	다층 거냥
사용자 마찰	높음	중간	드래그 1회
데이터 주권 · 온프레미스	경우별	외부 전송	완전 자체 보관
커스터마이즈 · 도메인 특화	제한	불가	문항·정책 자유
위조 방지 구조	클라이언트 신뢰	부분	영수증 체인 서버검증



단일 우회 불가

성격이 다른 방어를 겹쳐, 하나를 뚫어도 다음 계층이 남습니다. 봇 운영자의 우회 비용이 비대칭적으로 커집니다.



데이터 주권

사용자 행동을 외부로 보내지 않습니다. 국내 규제·프라이버시 요건에 부합하는 온프레미스 설계.



도메인 특화

문항·난이도·정책을 서비스 특성(이러닝 등)에 맞춰 조율. 범용 캡차가 못 하는 맞춤 방어.

정직한 포지셔닝. 봇 차단은 '완결'이 아니라 '군비경쟁'입니다. CatChap의 강점은 절대적 무결이 아니라, **우회 비용을 계속 끌어올리고 새 공격을 데이터로 학습하는 구조** — 방어가 스스로 진화한다는 점입니다.

STATUS & ROADMAP

09

현재 성숙도와 다음 단계

핵심 방어는 라이브로 가동 중이며, 행동 AI 실집행 승격과 정밀봇 후속 방어가 다음 마일스톤입니다.

가동 현황 · LIVE

- **LIVE** 오브젝트 드래그 캡차 · 은닉 히트영역 · 임시 ID 리매핑
- **LIVE** 적응형 Proof-of-Work
- **LIVE** 허니팟 · 드롭존 랜덤화 · 문항 회전
- **LIVE** 신뢰 이벤트 배치채널(영수증 체인)
- **LIVE** 행동 휴리스틱 · 자동화/클러스터 탐지 · 레이트리밋
- **SHADOW** behavior-AI (LightGBM) 예측 상시 기록

1,660

검수 완료 문항

13

방어 기법(5계층)

로드맵 · NEXT

- **핵심 방어 스택 구축** 완료
PoW·허니팟·회전·배치채널·behavior-AI shadow까지 통합 배포
- **베타 공개 & 데이터 수집** 진행
실사용자·레드팀 봇을 같은 창에서 수집해 사람/봇 라벨 확보
- **행동 AI 실집행 승격**
오탐률 기준 통과 시 shadow → active 2단계 전환
- **정밀봇 후속 방어**
IP/ASN 평판 · TLS/헤더 지문 · 이력닝 재생 교차검증
- **접근성 대체 수단**
드래그가 어려운 사용자를 위한 대체 인증 경로

지금 이 순간, 베타 공개를 준비 중이며, 실프래픽이 열리는 즉시 사람 데이터와 레드팀 봇 데이터를 동일한 조건에서 수집합니다. 이 데이터가 행동 AI를 실집행으로 끌어올리는 마지막 근거가 됩니다.



CatChap / Security

THANK YOU

봇은 걸러내고, 사람은 흐르게.

CatChap Security CAPTCHA는 '인식을 시험하는' 캡차의 시대를 넘어, **행동을 검증하고 데이터로 진화**하는 보안 인증을 지향합니다. 누구나 3초에 통과하되, 봇에게는 단 하나의 우회로도 남기지 않는 것 — 그것이 우리가 만든 방어입니다.

Behavioral Verification

Defense-in-Depth

Self-evolving Security

Data Sovereignty